

Compliance Assessment Report

Client: BSU

Generated On: 2025-09-17 22:51:44

Executive Summary

Total Sentences: 298

Missing: 191

Weak: 46

Aligned: 0

Control Coverage Report

Sentence	Status	Framework	Closest Control	Suggested Improvement
This program defines methods, rules, procedures, and other requirements necessary for the secure and reliable operation of the BSU information systems and network infrastructure. To manage systems and enforce security, BSU may log, review, and otherwise utilize any information stored on or passing through its systems. This program defines baseline control measures in a program of information security everyone who	Missing	SOC 2	and system requirements relevant to security,	The company is committed to establishing and enforcing robust security measures to ensure the secure and reliable operation of our information systems and network infrastructure, in line with SOC 2 system requirements relevant to security [1]. We recognize the importance of maintaining the security, availability, and confidentiality of our systems and the data they contain [3]. To this end, we
connects to the BSU network is expected to be familiar with and to consistently follow. The information carried in the BSU network and information systems: the data, hardware, software and people that use them are necessary for the performance of almost every essential activity at the University. ■ The development, implementation, and enforcement of University-wide information systems security program and				will employ secure algorithms and operating systems that provide mechanisms for creating and maintaining secure audit logs [2]. These logs will be used to manage our systems, enforce security, and prevent unauthorized access to our information. All individuals who connect to our network are expected to be familiar with and consistently follow our information security program, which outlines baseline control

Sentence	Status	Framework	Closest Control	Suggested Improvement
related recommended guidelines, operating procedures, and technical standards. Reflecting these compromises, fulfilling goals set by USM Security Standards and BSU Policy, this department defines specific information security standards, procedures and controls for the University. BSU Policy recognition is also required before network access is granted. These access control packages must prevent unauthorized use of the machines and unauthorized access to				measures [1]. This program includes guidelines, operating procedures, and technical standards that reflect our commitments to security, availability, and confidentiality [3]. Before network access is granted, individuals must acknowledge and agree to abide by our policy. We will implement access control measures to prevent unauthorized use of our systems and unauthorized access to our information [1]. If a system is
BSU information. If a system that is used to process BSU information has been set up by the Information Systems department, users can rely on the fact that all software on this system is licensed and authorized. This methodology must ensure that the software will be adequately documented and tested before it is used for critical BSU information.				set up by our Information Systems department, users can trust that all software on the system is licensed and authorized. We will ensure that all software is adequately documented and tested before it is used to process critical company information [1]. In conclusion, our company is committed to fulfilling our security commitments and system requirements, and we will continually review
				and update our policies and procedures to ensure they are effective and compliant with the SOC 2 and CIS Controls v8 frameworks [1, 2, 3].
The standards for information security contained in this document are best practice and are rooted in the University System of Maryland (USM) Security Standards and the National Institute of Standards and Technology (NIST) Cybersecurity Framework.	Missing	CIS Controls v8	• Documentation on alignment with the NIST® Cybersecurity Framework	Our organization is committed to maintaining the highest standards of information security. Our policies and procedures are rooted in best practices and align with the CIS Controls v8 framework, specifically through our adherence to the NIST® Cybersecurity Framework (1). We also reference the guidance provided by the Institute of Standards and Technology, Gaithersburg, MD, as outlined in the NIST Cybersecurity

Sentence	Status	Framework	Closest Control	Suggested Improvement
				White Paper (CSWP) NIST CSWP 29 (2). Additionally, our information security management system is designed in accordance with the ISO 27001 family of standards (3). This comprehensive approach ensures that we remain at the forefront of cybersecurity, protecting our systems, data, and stakeholders from potential threats.
Legislative controls contained in FERPA, PIPA and Gramm Leach Bliley laws are include as well.	Missing	ISO 27001	All relevant legislative statutory, regulatory, contractual require-	The company is committed to adhering to all relevant legislative, statutory, regulatory, and contractual requirements, as well as business requirements, as outlined in the ISO 27001 framework [1][2]. This includes ensuring compliance with all relevant legislation and regulation where necessary [3]. As part of this commitment, the company will include controls contained in FERPA, PIPA, and the Gramm Leach Bliley
				laws. The company will continually review and update its policies to ensure ongoing compliance with these requirements.
Care was taken to communicate technical concepts in plain English, avoiding technical terms and acronyms where possible.	Missing	CIS Controls v8	Version 8, CIS created a glossary to remove ambiguity of terminology. Some ideas	In alignment with the CIS Controls v8 and NIST CSF, our company is committed to fostering clear and effective communication of cybersecurity concepts. We will utilize a common language that is comprehensible to all stakeholders, both within and outside the organization. We will ensure that technical jargon and acronyms are replaced with plain English, where possible, to remove ambiguity and
				enhance understanding. This approach will also facilitate a management language that executives can readily comprehend, thereby promoting informed decision-making at all levels of the organization [1,2,3].

Sentence	Status	Framework	Closest Control	Suggested Improvement
The document audience is all BSU employees and business partners.	Weak	ISO 27001	All employees of the organization and, where relevant, contrac-	The policy statement is: All employees of the organization, as well as relevant contractors and business partners, are required to adhere to our cybersecurity policy, which is implemented organization-wide. This policy is aligned with the guidelines provided by the Software Alliance and is designed to ensure the comprehensive security of our information systems. We encourage all employees and partners to
				familiarize themselves with the updated BSA framework available at https://www.bsa.org/reports/updated-bsa-framework- to understand our cybersecurity commitments and responsibilities. [1][2][3]
Examples and details designed to illustrate why information security is important are presented.	Missing	ISO 27001	identifies the information security risks:	N/A
We hope to encourage understanding and improve awareness the importance of information security across the many groups of Users with varying degrees of education that comprise the BSU family. As a result, information security now must be a critical part of the BSU business environment. Supporting Educational Mission and Business Objectives - This document outlines information security requirements prepared to	Missing	ISO 27001	the organization's own requirements for its information security management system; and	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
ensure that BSU is able to support further growth of the University, and support a consistently high level of service to our constituents. This means that users at BSU must step in and play an important role in the information security. Information security is now a team effort requiring the participation of everyone who come into contact with BSU information				
or information systems. ■ Enable management and other employees to make appropriate decisions about information security. MANAGEMENT SUPPORT FOR INFORMATION SECURITY Critical Business Function – Information is a foundation of higher education and research. If there was a serious security problem with this information or information systems, BSU could suffer serious consequences including loss of current and prospective student enrollment,				

Sentence	Status	Framework	Closest Control	Suggested Improvement
reduced revenues, and degraded reputation. BSU Team Effort Required - The tools available in the information security field are relatively unsophisticated. INFORMATION SECURITY RESPONSIBILITIES Information Security Committee – The committee provides oversight and advice regarding information systems security and privacy assurance for BSU. Committee members include subject matter experts in information security and assurance. Enterprise IT Security Department - The				
Enterprise IT Security Department is the central point of contact for all information security matters at BSU. Enterprise IT Security Department must: ■ Perform access control administration activities, ■ Monitor the security of BSU information systems, ■ Provide information security training and awareness programs to BSU employees. The department is responsible for providing management with reports about the current state				

Sentence	Status	Framework	Closest Control	Suggested Improvement
of information security at BSU. The Enterprise IT Security Department is also responsible for organizing a computer incident response team to promptly respond to virus infections, system break-ins, system outages, and similar information security problems. Acting as internal technical and policy consultants, it is this department's responsibility to create workable information security compromises that take into consideration the needs of				
Users, Custodians, and Owners, while supporting the University Strategic Plan and Mission.				
This document provides a definitive statement of information security policies and practices to which all employees are expected to comply.	Missing	ISO 27001	Information security policies	N/A
It is intended to: ■ Acquaint employees with information security risks and the expected ways to address these risks.	Missing	ISO 27001	identifies the information security risks:	N/A
■ Clarify employee responsibilities and duties with respect to the protection of information resources.	Missing	ISO 27001	Information security responsibilities and duties that remain valid	N/A
■ Coordinate the efforts of different groups within the University so that information resources are properly and consistently protected, regardless of their location, form, or supporting technologies.	Missing	ISO 27001	Objective: To provide management direction and support for information security in accordance with	N/A
Everyone recognizes that a highway system and motor vehicles are essential to commerce.	Missing	ISO 27001	state their and the organization's responsibilities for information	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
People now appreciate how information systems made up of computers and networks are another infrastructure essential to commerce.	Weak	PCI DSS	needed for the size and complexity of the merchant's operations. The policy document must be provided to all personnel, so they are aware of their	N/A
Just as every driver has a role to play in the orderly and safe operation of the transportation infrastructure, there are information security roles and duties for every employee at BSU. Just as car manufacturers are required to provide safety belts with vehicles, system designers at BSU are required to include necessary security measures such as user access restrictions based	Missing	CIS Controls v8	computer, domain, or the whole enterprise information technology infrastructure.	N/A
on job function and the need to know.				
For example, it is a driver's duty to report accidents, and it is an employee's duty to report information security problems.	Missing	ISO 27001	Information security responsibilities and duties that remain valid	N/A
Sometimes called "standard of due care controls", these security measures are the minimum required to prevent a variety of problems including, but not limited to: theft fraud and embezzlement, ■ ■ ■ research raiding and espionage, ■ sabotage, ■ errors and omissions, ■ system unavailability, and ■ loss of confidence and damage to reputation The BSU Policies citations listed above	Missing	ISO 27001	Information security responsibilities and duties that remain valid	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
define general University goals, expectations, and responsibilities with regard to technology use. The BSU Policies and the DIT rules define the minimum controls necessary to prevent legal problems such as allegations of negligence, breach of fiduciary duty, or privacy violation.				
This document contains DIT rules that details both reasonable and practical ways for all of us at BSU to avoid risk and prevent unnecessary losses.	Missing	ISO 27001	mation security and of any security requirements.	N/A
BSU critically depends on continued citizen confidence.	Missing	CIS Controls v8	For a larger or more complex enterprise, there will be multiple security baseline	N/A
This confidence has gradually increased and is the result of many years of dedicated effort on the part of BSU students, faculty, staff, and leadership.	Missing	ISO 27001	b) determine all controls that are necessary to implement the information security risk treatment	N/A
While confidence takes many years to earn, it can be rapidly lost due to problems such as denial of service attacks that disrupt the educational process, system outages that stop intra-university communication, or the theft of unsecured personally identifiable information (PII) resulting in potential identity theft.	Missing	PCI DSS	Details of how legal constraint prevents	N/A
The trust that the community we serve has in the University is a competitive advantage that must be continuously nurtured and grown.	Weak	ISO 27001	Risk management — Principles and guidelines	N/A
This information security initiative is designed to protect these efforts.	Weak	CIS Controls v8	CIS Critical	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
The document is also intended to support BSU's reputation for providing high quality and affordable educational opportunities for a diverse student population of Maryland citizens and the global community through the effective and efficient management of its resources.	Weak	NIST CSF	Given the importance of continual improvement, an organization can repeat these steps as	N/A
Because the prevention of security issues is considerably less expensive than correction and recovery, this document will help reduce the overall cost of University operations.	Missing	NIST CSF	data breaches could lead to identity theft. However, privacy risks can also arise by	N/A
Consistent Compliance Essential - A single unauthorized exception to information security measures can jeopardize the entire university community, our business partners and even our educational partners in the University of Maryland System (USM). ■ To ensure related compliance requirements are addressed, e.g., privacy, security, and administrative regulations associated with University System of Maryland (USM), Federal and Maryland laws.	Missing	CIS Controls v8	is about harnessing the experience of a community of individuals and enterprises to	N/A
The interconnected nature of information systems requires that all employees observe a minimum level of security. All Users are required to follow all security requirements defined by Owners, implemented by Data Stewards and Custodians, or established by the Enterprise IT Security Department.	Missing	ISO 27001	Information security objectives and plans to achieve them	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
This document defines that minimum level of due care.	Missing	ISO 27001	Objective: To provide management direction and support for information security in accordance with	N/A
In some cases, these requirements will conflict with other objectives such as improved efficiency and minimized costs.	Missing	ISO 27001	Knowledge gained from analysing and resolving information secu-	N/A
Top management has examined these trade-offs and has decided that the minimum requirements defined in this document are appropriate for all employees at BSU.	Missing	ISO 27001	the information security risks associated with information and	N/A
As a condition of continued employment, all employees, contractors, consultants, and temporaries, must consistently observe the requirements set forth in this document.	Weak	CIS Controls v8	Higher Education Community Vendor	N/A
Many of the needed tasks cannot be achieved with products now on the market.	Weak	CIS Controls v8	and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.	N/A
Information and information systems are distributed to the office desktop, and are used in remote locations; the employee's role has become an essential part of information security.	Missing	ISO 27001	Information security requirements for mitigating the risks associ-	N/A
Information security is no longer the exclusive domain of the Division of Information Technology.	Missing	ISO 27001	Objective: To ensure that information security is an integral part of information systems across the	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Members are designated by the Division of Information Technology (DIT) Vice President/Chief Information Officer (CIO) to provide advice for CIO specific responsibilities that include: ■ The development, implementation, and maintenance of a University-wide strategic information systems security plan. In many cases, a manager in DIT will act as the Custodian. If a Custodian is not clear, based on existing information	Weak	PCI DSS	Description of Requirement	N/A
systems operational arrangements, then the Chief Information Officer will designate a temporary DIT Custodian. DIT assigns the standard basic information security awareness training based upon position/role.				
■ The process of handling requested program exceptions, advise the University administration on related risk issues and recommend appropriate actions in support of the University's larger risk management programs.	Missing	PCI DSS	Appendix D: Explanation of Requirements Noted as Not Applicable	N/A
■ Ensure appropriate risk mitigation and control processes for security incidents.	Missing	SOC 2	requirements as they relate to security, availability, and confidentiality.	N/A
Information Owners – The Division Vice President is or designates top-level managers in each University area as the Owners of all types of information used for area business activities.	Missing	ISO 27001	Management shall require all employees and contractors to apply	N/A
Each type of system information must have an Owner.	Missing	ISO 27001	opportunities and any needs for changes to the information security management system.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
When information Owners are not clearly identified by appointment or organizational design, the Chief Information Officer must make a temporary designation (until the area Vice President can appoint a designee).	Weak	PCI DSS	Note: Only entities that have a legitimate and documented technological or business constraint can	N/A
Information Owners do not legally own information all university information belongs to the institution.	Missing	ISO 27001	operation of information security within the organization.	N/A
They are instead members of the BSU management team who make decisions on behalf of the University.	Missing	ISO 27001	the implications of not conforming with the information security management system requirements.	N/A
Information Owners or their delegates must make the following decisions and perform the following activities: ■ Formulate specific job function profiles that will be granted access to University information. ■ Determine the proper access based on job function profiles and determine the proper use of university information. ■ Supervise department employee use of university information under their control.	Missing	ISO 27001	Information security responsibilities and duties that remain valid	N/A
■ Approve information-oriented access and control privileges for specific job function profile. ■ Approve information-oriented access control requests that do not fall within the scope of existing job function profiles. Information Access Approval Process - An employee's manager must initiate the access control approval process, and the privileges granted remain in effect until the employee's job function profile changes or	Missing	ISO 27001	cies for information	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
the employee leaves BSU.				
■ Select a data retention period for their information.	Missing	ISO 27001	the organization's own requirements for its information security management system; and	N/A
■ Designate original sources for information.	Missing	CIS Controls v8	applicable to the business's needs. In some cases, the security risk of an exception is	N/A
■ Employ special controls needed to protect information, such as additional input validation checks at the data point of entry or indicate more frequent backup procedures.	Missing	ISO 27001	Compliance with	N/A
■ Define acceptable limits on the quality of their information, such as accuracy, timeliness, and time from capture to usage.	Missing	CIS Controls v8	Establish and Maintain Security Incident Thresholds	N/A
■ Approve all new and different uses of their information.	Missing	ISO 27001	state their and the organization's responsibilities for information	N/A
■ Approve all new or substantially enhanced application systems that use their information before these systems are moved into production operational status.	Missing	SOC 2	of the system and have access to confidential information.	N/A
■ Review reports about system intrusions and other events that are relevant to their information.	Weak	ISO 27001	The organization shall determine its requirements for information	N/A
■ Review and correct current production uses of their information.	Missing	PCI DSS	do not store, process, or transmit any account data in electronic format on their systems or premises.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
■ Select a sensitivity classification category relevant to their information with consultation of the BSU General Counsel, and review classifications every five years. To assist in the appropriate handling of information, a sensitivity classification hierarchy must be used throughout BSU. BSU uses four sensitivity classification categories: Public - This information has been specifically approved for public release by Public Relations	Weak	NIST CSF	Organizations.	N/A
department or Marketing Department Managers.				
■ Select a criticality category relevant to their information with consultation of the Enterprise IT Security Department so that appropriate safeguards and contingency planning can be performed. While information systems contingency planning is the responsibility of information Custodians, the Enterprise IT Security Department must provide technical consulting assistance related to emergency response procedures and disaster recovery.	Missing	NIST CSF	3. Create the Organizational Profile. Determine what types of information the Profile	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Information Owners must designate an alternative person to act if they are absent or unavailable. When both the Owner and the back-up alternative Owner are unavailable, the Department Manager who ordinarily supervises the handling of information may make immediate Owner decisions (and seek the Information Owners subsequent approval).	Missing	CIS Controls v8	control lists, and role-based access control lists.	N/A
Owners may not delegate ownership responsibilities to third-party organizations such as outsourcing organizations, or to any individual who is not a full-time BSU employee.	Missing	CIS Controls v8	Retain data according to the enterprise's data management process. Data retention must include both minimum and maximum timelines.	N/A
Data Stewards (aka Application User Coordinators) are Employee's Immediate Manager – Information Stewards must make the following decisions and perform the following activities: ■ Review and correct security reports that indicate those users who currently have access to university information within their department.	Missing	PCI DSS	Examine information sources for	N/A
■ Authorize new users to access university information and de-authorize users who no longer fit a job function profile.	Missing	CIS Controls v8	described in CIS Control 3, Data Protection. This should include backup procedures	N/A
The employee's immediate manager is the Data Steward who must approve a request for system access based on existing job function profiles.	Missing	CIS Controls v8	that explicit error checking is performed and documented for all input, including for size, data type, and acceptable ranges or formats.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
If a job function profile does not exist, it is the manager's responsibility to create the function profile, obtain the approval of relevant Owners, and inform the Enterprise IT Security Department.	Missing	ISO 27001	When creating and updating documented information the organization shall ensure appropriate:	N/A
When an employee leaves BSU, it is the responsibility of the employee's immediate manager to promptly inform the Enterprise IT Security Department that the privileges associated with the employee's user ID must be revoked. When the project is complete or when the non-employees stops working with BSU, the Department Manager must inform the PeopleSoft Enterprise Functional Support and Enterprise IT	Missing	CIS Controls v8	new software or to support new operational requirements.	N/A
Security Departments must immediately revoke the privileges of these non-employees. Departures From BSU - When a user leaves BSU, all system privileges and access to BSU information must cease immediately. For example, departed users must not be permitted to continue to access the BSU network. All work done by users for BSU is BSU property, and it too must remain				

Sentence	Status	Framework	Closest Control	Suggested Improvement
with BSU when users depart. Personal Computer Connections - Employees must not connect their own computers with BSU computers or networks without prior authorization from DIT. BSU also must reserve the right to immediately terminate network connections with all third-party systems not meeting such requirements.				
User IDs are specific to individuals, and must not be reassigned to, or used by, others. Unique User IDs - Each user must be assigned their own unique user ID. Re-use of user IDs is not permitted. User IDs are linked to specific people, and are not associated with computer terminals, departments, or job titles.	Missing	CIS Controls v8	Collect, alert, review, and retain audit logs of events that could help detect, understand, or recover from an attack.	N/A
Data Custodians - Custodians are DIT information technology specialists: database administrators; system administrators; and functional analysts who physically or logically access information and administer information systems. Like Owners, Custodians are specifically designated for different types of information. Custodians follow the instructions of Owners, operate systems on behalf of Owners, but also serve users authorized by Owners. If requested, Custodians additionally	Missing	ISO 27001	The organization shall retain documented information as evidence of the results of management reviews.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
provide reports to Owners about information system operations and information security problems. Custodians are responsible for safeguarding the information in their possession, including implementing access control systems to prevent inappropriate disclosure, and developing, documenting, and testing information systems contingency plans. Custodians also define information systems architectures and provide technical consulting to Owners so that information systems can be built and				
run to best meet the University Mission.				
Custodians must define the technical options, such as systems criticality categories, and permit Owners to select the appropriate option for their information. Production systems also must have designated Owners and Custodians for the critical information they process.	Missing	CIS Controls v8	Establish and Maintain a Severity Rating System and Process for	N/A
Information Users – There are two types of Users: General Users are not specifically designated, but are broadly defined as any person who accesses the BSU network.	Missing	ISO 27001	When planning for the information security management system, the organization shall consider the	N/A
Departmental Data Users are employees or contractors and consultants with access to internal information or internal information systems.	Missing	ISO 27001	state their and the organization's responsibilities for information	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
All Users must familiarize themselves with, and act in accordance with, BSU information security requirements. Every BSU user ID and related password is intended for the exclusive use of a specific individual. At this point, all BSU information disclosed to users must be returned. All default passwords set by the hardware or software vendor must be changed before the involved	Missing	CIS Controls v8	Some users have access to enterprise assets or data they do not need for their role; this	N/A
system can be used for BSU business activities.				
Users also must complete information security awareness training. The training required for network access is information security awareness training approved by the IT Enterprise Security Department. (Ask Enterprise IT Security to assign the additional training).	Missing	CIS Controls v8	Designate one key person, and at least one backup, who will manage the enterprise's incident handling process.	N/A
Users must request access from their immediate manager, and report all suspicious activity and security problems.	Missing	CIS Controls v8	risks. For example: executives manage more sensitive data; system administrators have	N/A
In this regard, Enterprise IT Security Department conducts an annual risk analysis and remediation report.	Weak	ISO 27001	A.9.2 User access management	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
INFORMATION SENSITIVITY CLASSIFICATION Reasons For Classification - As a member of the University System of Maryland (USM) and a state university, BSU takes seriously its commitment to respect and protect the privacy of its students, alumni, faculty and staff, as well as to protect the confidentiality of information important to the University's academic mission.	Missing	ISO 27001	Employees and contractors using the organization's information	N/A
BSU classifies its information assets into categories for the purpose of determining who is allowed to access the information and what security precautions must be taken to protect it against unauthorized access. BSU must protect this equipment and the information it transmits by limiting access to the network to users who have been trained in, and agree to, its proper	Missing	CIS Controls v8	administrator, and service account access should be based on enterprise role and need.	N/A
use. Information Privacy - A wide variety of parties have entrusted their information to BSU for business purposes, and all employees at BSU must do their best to safeguard the privacy and security of this information. INTELLECTUAL PROPERTY RIGHTS Legal Ownership - With the exception of material clearly owned by third parties, BSU is the legal Owner of all business				

Sentence	Status	Framework	Closest Control	Suggested Improvement
information stored on or passing through in its systems. Unauthorized disclosure of this information will not cause problems for BSU, its customers, or its business partners. Unauthorized disclosure of this information to outsiders may be against laws and regulations, or may cause problems for BSU, its customers, or its business partners. Unauthorized disclosure of this information to people without a				
business need for access may be against laws and regulations, or may cause significant problems for BSU, its customers, or its partners. Handling Of Sensitive Information - Sensitive (Confidential or Restricted) information must not leave BSU offices. This type of information is already widely distributed within BSU, or it could be distributed within the organization without advance permission from the				
information Owner. Only Public Information Posted - Unless the relevant information Owner has approved in advance, employees must not place anything other than BSU public information in a directory, on a server, or in any other location where unknown parties could readily access it. Confidential - This information is sensitive intended for use within BSU, and in some cases within				

Sentence	Status	Framework	Closest Control	Suggested Improvement
affiliated organizations, such as BSU partners. Unless the BSU General Counsel has signed a specific written agreement, all business-related information developed while a user is employed by BSU is the property of the University.				
This hierarchy provides a shorthand way of referring to sensitivity, and can be used to simplify information security decisions and minimize information security costs.	Missing	CIS Controls v8	profiles based on job function and mission. Small enterprise units may have regulatory	N/A
One important intention of a sensitivity classification system is to provide consistent handling of the information, no matter what form it takes, where it goes, or who possesses it. For this reason, it is important to maintain the labels reflecting sensitivity classification categories.	Missing	CIS Controls v8	There should be a process where privileges are granted and revoked for user accounts.	N/A
Examples are marketing brochures, material posted to the BSU web page and BSU departmental phone numbers.	Missing	PCI DSS	All users are assigned a unique ID before access to	N/A
Internal - This information is not approved for public release.	Missing	CIS Controls v8	data/asset owners who are responsible for each component of a business process.	N/A
Unauthorized disclosure of this information to outsiders may affect University interests.	Missing	CIS Controls v8	data/asset owners who are responsible for each component of a business process.	N/A
Examples are employee office phone numbers, email addresses and office manuals.	Weak	CIS Controls v8	Designate one key person, and at least one backup, who will manage the enterprise's incident handling process. Management personnel	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Restricted - This information is sensitive private or otherwise sensitive in nature and must be restricted to those with a legitimate business need for access. Access to "Confidential" and/or "Restricted" information must be granted only when a legitimate business need has been demonstrated and job function profile access has been approved in advance by the information Owner. Restricted information is	Missing	SOC 2	to individuals within the entity with authority to ensure policies and other system requirements are	N/A
available on a very limited basis. Access to special hardware and software must be restricted based on business need and job function profile. Student and patient as well as employee account data is Sensitive (Confidential or Restricted) and access must be strictly limited based on business need for such access.				
Decisions about the provision of access to this information must be cleared through the information Owner.	Missing	ISO 27001	Information systems	N/A
Examples are customer transaction account information (may be protected by GBLA) and employee performance evaluation records, student information (may be protected by FERPA), acquisition plans, and legal information protected by attorney-client privilege.	Missing	ISO 27001	Groups of information services, users and information systems	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Default Category - If information is not marked with one of these categories it should be considered Confidential. Information that falls into the Confidential or Restricted, categories is designated Sensitive.	Missing	ISO 27001	Employees and contractors using the organization's information	N/A
Labeling - The Owner or creator of information must designate an appropriate label, and the user or recipient of this information must consistently maintain an assigned label. Information Labeling - In addition to maintaining the labels mentioned in "Information Sensitivity Classification," users must maintain information about source, date, and usage restrictions for all information provided by third parties.	Missing	ISO 27001	All relevant information security requirements shall be established	N/A
Labels for sensitive information must be used in the subject field of electronic mail messages or paper memos.	Missing	NIST CSF	o PR.AA-01: Identities and credentials for authorized users, services, and hardware are	N/A
Labels for sensitive information must appear on the outside of floppy disks, magnetic tape reels, CD-ROMs, audiocassettes, and other storage media.	Missing	CIS Controls v8	responsibilities. Training can include general security principles and application security standard practices. Conduct training at least	N/A
If a storage volume such as a disk contains information with multiple classifications, the most sensitive category should appear on the outside label.	Missing	ISO 27001	ensure that only authorized personnel are allowed access.	N/A
Likewise, when creating a collection of information from sources with various classifications, the collection must be classified at the highest sensitivity level of the source information.	Missing	ISO 27001	The organization's information security management system shall include:	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Handling Instructions - All users must observe the requirements for handling information based on its sensitivity.	Missing	ISO 27001	operation of information security within the organization.	N/A
For more information on these definitions, see the BSU Data Classification Quick Reference Table.	Missing	NIST CSF	enterprise risk management programs, and their performance is monitored throughout	N/A
Owners may designate additional controls to further restrict access to, or to further protect university information under their control.	Missing	CIS Controls v8	as "Sensitive," "Confidential," and "Public," and classify their data according to those labels. Review and update the	N/A
ACCESS CONTROLS Network Access Philosophy – The BSU network is a system of hardware components: computing devices, routing devices, switching devices, fiber optic and copper cables, etc. Within the BSU network (e.g. Access Control Packages - All portable and remote computers that are under the control of BSU employees and that are used to process BSU business information must be	Missing	CIS Controls v8	to sensitive data an enterprise holds related to finances, intellectual property, and	N/A
protected with a DIT access control package approved by the Enterprise IT Security Department.				
that transmit all types of information in the form of data bits.	Missing	ISO 27001	a) establishes and maintains information security risk criteria that include:	N/A
Network Access Approval Process – The Human Resources Department (HR) must initiate the network access control approval process for all new employees.	Missing	CIS Controls v8	Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as "Sensitive,"	N/A
These steps are required for network access: 1.	Missing	CIS Controls v8	as "Sensitive," "Confidential," and "Public," and classify their data according to those labels. Review and update the	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
HR determines that a new employee has been hired by a department and notifies DIT (including the IT Enterprise Security Department).	Missing	SOC 2	Access to confidential information from outside the boundaries of the system and disclosure	N/A
The new employee is given a BSU email account.	Weak	CIS Controls v8	principally surrounds employee and financial information.	N/A
Additional training may be assigned by the information data steward, the new employee manager, or data owner based on specific employee role information sensitivity.	Missing	SOC 2	information is restricted to authorized internal	N/A
Upon completion of awareness training by the new employee, DIT grants the proper network access, which remain in effect until the employee leaves BSU.	Missing	SOC 2	Access to confidential information from outside the boundaries of the system and disclosure	N/A
Information Access Philosophy - Access to "Public" information is not restricted with access controls that discriminate by specific user.	Missing	CIS Controls v8	principally surrounds employee and financial information.	N/A
For example, "Public" information is available on the BSU web site, and "Internal" information is available on the BSU intranet.	Missing	ISO 27001	Information access	N/A
If either of these two events occur, the manager must notify the PeopleSoft Enterprise Security Analyst in the Functional Support Team and Enterprise IT Security Departments immediately.	Missing	ISO 27001	Confidentiality or non-	N/A
All non-employees, contractors, consultants, temporaries, and outsourcing organizations must be authorized in the same manner.	Missing	ISO 27001	restricted in accordance with the access control policy.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
The relevant data steward or manager must review the need for the continuing privileges of non- employees every three months.	Missing	ISO 27001	Objective: To prevent unauthorized disclosure, modification, removal or destruction of information	N/A
For example, contact lists must remain with BSU.	Missing	SOC 2	Confidential information is protected during	N/A
For example, a computer program component written by a member of the PeopleSoft Applications department while employed by BSU is BSU property and must remain with BSU.	Missing	CIS Controls v8	as "Sensitive," "Confidential," and "Public," and classify their data according to those labels. Review and update the	N/A
This user ID follows an individual as they move through the University.	Missing	ISO 27001	An appropriate set of procedures for information labelling shall be	N/A
It must be permanently decommissioned when a user leaves BSU.	Missing	CIS Controls v8	for the enterprise. Enterprises may use labels, such as "Sensitive," "Confidential," and	N/A
While user IDs can be shared in electronic mail messages and in other places, passwords must never be shared with anyone. ELECTRONIC MAIL Sharing And Forwarding - Electronic mail accounts, like user IDs, are for specific individuals and must not be shared.	Missing	CIS Controls v8	for the enterprise. Enterprises may use labels, such as "Sensitive," "Confidential," and	N/A
Information systems technicians have all the privileges they need to do their job, and must never obtain a user's password.	Missing	CIS Controls v8	Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as "Sensitive,"	N/A
With the exception of Internet pages, intranet pages, and other places where anonymous interaction is both generally understood and expected, anonymous and guest user IDs are not permitted unless approved in advance by the Enterprise IT Security Department.	Missing	CIS Controls v8	communication plans. To derive data sensitivity levels, enterprises need to catalog	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Privilege Deactivation - After a period of no activity defined in minutes by the Enterprise IT Security Department, online sessions with multi-user machines must be terminated automatically. Dormant user IDs on multi-user computers that have no any activity for a period defined in weeks by the Enterprise IT Security Department must have their privileges automatically revoked.	Missing	PCI DSS	Examine procedures for setting	N/A
Users must be sure to log-off from multi-user computers when they leave their desks for any more than a few minutes.	Missing	CIS Controls v8	Classify service providers. Classification consideration may include one or more characteristics, such as data sensitivity, data volume,	N/A
Users of multi-user machines should not leave files on these machines as they may be deleted at any time.	Missing	ISO 27001	To limit access to information and information processing facilities.	N/A
User Authentication - All production information system user IDs must have a linked password or a stronger mechanism such as a dynamic password token, to ensure that only the authorized user is able to utilize the user ID.	Missing	ISO 27001	Access to networks	N/A
Users are responsible for all activity that takes place with their user ID and password or other authentication mechanism.	Missing	ISO 27001	to protect the transfer of information through the use of all types	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
A user must change their password immediately if they suspect that it has been discovered or used by another person. If a user suspects that somebody else may know his or her password, the password must be changed immediately. Where systems support it, fixed passwords must be required to change every 120 days and passwords must be changed the first	Missing	ISO 27001	Where required by the access control policy, access to systems and	N/A
time they are used.				
Users must notify the Enterprise IT Security Department if other access control mechanisms are broken or if they suspect that these mechanisms have been compromised PASSWORD MANAGEMENT Choosing Passwords - Users must choose difficult-to-guess passwords.	Missing	ISO 27001	An access control policy shall be established, documented and	N/A
Fixed passwords must not be found in the dictionary and must not be a reflection of the user's personal life.	Missing	ISO 27001	Access to networks	N/A
All fixed passwords must be at least eight characters, and this minimum length must be enforced automatically where systems support it. Users must choose fixed passwords that include both alphabetic and numeric characters.	Weak	ISO 27001	Objective: To ensure that employees and contractors are aware of and fulfil their information security	N/A
Changing Passwords - User-chosen fixed passwords must not be reused or recycled.	Missing	PCI DSS	an account is granted.	N/A
The DIT Help Desk will not reset user passwords unless the user can establish their identity.	Missing	CIS Controls v8	Conduct Role-Specific Security Awareness and Skills Training	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Presenting a valid government ID and BSU ID is sufficient proof of identity.	Missing	ISO 27001	assignment of current employees; or the hiring or contracting of competent persons.	N/A
Protecting Passwords - Users must not share a fixed password with anyone, including managers, support technicians, and co-employees.	Missing	CIS Controls v8	enterprise activities. If the enterprise has remote workers, training must include guidance to ensure that all users	N/A
Authorized mechanisms to share information such as local BSU network server shared directories, BSU electronic mail, or BSU intranet pages.	Weak	ISO 27001	Access to networks	N/A
Passwords must not be stored in any computer files, logon scripts or computer programs, unless the passwords have been encrypted. Passwords must not be written down unless a transformation process has concealed them, or they are physically secured, such as placed in a locked file cabinet.	Missing	ISO 27001	Information access	N/A
A management tool enforces these rules - it is transparent to the end user.	Missing	ISO 27001	Documented information of external origin, determined by the organization to be necessary for	N/A
PRIVACY Expectations Of Privacy - Users must have no expectation of privacy when using university information systems.	Missing	ISO 27001	restricted in accordance with the access control policy.	N/A
BSU may capture user activity such as telephone numbers dialed and web sites visited.	Missing	ISO 27001	A.9.1 Business requirements of access control	N/A
Private information must not be released without advance written authorization of the individual.	Weak	PCI DSS	confirmed security incident, including notification of	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
An important exception to this rule is that human life must always be preserved.	Missing	SOC 2	is restricted to authorized personnel to meet the entity's commitments and system requirements	N/A
Laws may provide other exceptions: Teachers, health care providers, emergency responders, and law enforcement are examples of job function profiles exempted in certain circumstances.	Missing	CIS Controls v8	privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.	N/A
One example of a business purpose is a faculty member's need to access a student academic record in order to provide informed counseling to the student.	Missing	ISO 27001	Users shall only be provided with access to the network and net-	N/A
THIRD-PARTY DISCLOSURES Preauthorization For Public Statements - All employees who will be delivering or otherwise disclosing official information about BSU must obtain preauthorization from the University Relations department.	Missing	ISO 27001	All employees and external party users shall return all of the	N/A
Only designated individuals are authorized to be spokespersons for BSU.	Weak	ISO 27001	Appropriate contacts with relevant authorities shall be maintained.	N/A
Unless an employee is one of these designated spokespersons, all inquiries from the media must be directed to University Relations.	Weak	CIS Controls v8	Ensure that only currently supported software is designated as authorized in the software inventory for enterprise assets. If software	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
BSU Non-Disclosure Agreements - whenever communications with third parties necessitate the release of sensitive BSU information, a standard non-disclosure agreement (NDA) must be signed by the third party. Third-Party Non-Disclosure Agreements - In some instances, before discussions can be commenced, third parties must require that employees at BSU sign their non-disclosure agreements (NDAs). Recipients of third party NDAs must forward	Missing	NIST CSF	Identify (ID)	N/A
these agreements to the BSU General Counsel for review and approval.				
Information released to these third parties must be limited to the topics directly related to the involved project or business relationship, and the disclosure must be approved in advance by the involved information Owner.	Weak	NIST CSF	o PR.PS-03: Hardware is maintained, replaced, and removed commensurate with risk	N/A
ACCEPTABLE USE OF THE INTERNET Not A Fringe Benefit - Internet access and electronic mail is provided as tools to students and employees for university business, scholarly activity, and academic research purposes.	Weak	CIS Controls v8	to secure email and communications adds another layer of user and network-based	N/A
Information Reliability - All information acquired from the Internet must be considered suspect until confirmed by separate information from a reliable source.	Missing	CIS Controls v8	policies and guidance not to reuse passwords should be developed.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Users must not rely on the alleged identity of a correspondent through outside email or the Internet.	Missing	SOC 2	(1) identification and authentication of authorized internal and external users; (2) restriction of	N/A
The identity of a person or organization is confirmed through authoritative methods such as digital certificates granted by third party verification or digital signatures.	Missing	CIS Controls v8	Users must also be automatically logged out of the system after a period of inactivity,	N/A
More information can be obtained from the Enterprise IT Security Department.	Missing	CIS Controls v8	Users must also be automatically logged out of the system after a period of inactivity,	N/A
Downloading Software - Users must not install software from the Internet unless specifically authorized to do so by the Information Systems or Enterprise IT Security Department.	Missing	CIS Controls v8	Disable Dormant Accounts	N/A
Users may download data files from the Internet, but must check these files for viruses before using them.	Missing	CIS Controls v8	files. They are not intended to be used by people, except for performing administrative	N/A
Copyright laws must be respected when downloading files. Users must assume that all materials on the Internet are copyrighted unless specific notice states otherwise.	Missing	CIS Controls v8	user's identity. Examples of authorization systems can include active directory, access	N/A
Sending Security Parameters - Users must not send any sensitive parameters such as credit card numbers, telephone calling card numbers, fixed passwords, or account numbers through the Internet unless the connection is encrypted end-to-end.	Missing	CIS Controls v8	protocols, such as certificates, and may incorporate user and/or device authentication.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
International Transfer Of Data - The movement of private or research information such as human resources records or sensitive research across international borders in some countries is illegal.	Missing	PCI DSS	• Passwords/passphrases are changed at least once	N/A
Before transferring any private or sensitive research information across a border, users must check with the BSU General Counsel to ensure that laws are not violated.	Missing	CIS Controls v8	passwords a user must manage. Users are recommended to use password manager	N/A
Setting Up Extra Services - The establishment of any connection to the BSU network with a third party is forbidden unless the Enterprise IT Security Department has approved the controls associated with this connection. ESTABLISHING NETWORK CONNECTIONS Connection Approval Required - BSU computers or networks may be connected to third-party computers or networks only after the Enterprise IT Security Department	Missing	CIS Controls v8	policies and guidance not to reuse passwords should be developed.	N/A
has determined that the combined systems will be in compliance with BSU security requirements. Firewalls Required - All connections between BSU internal networks and the Internet or any other publicly accessible computer network must include an approved firewall or related access control system. THIRD PARTY ACCESS Written Approval Required - Before third party users are permitted to reach BSU internal				

Sentence	Status	Framework	Closest Control	Suggested Improvement
systems through real-time computer connections, specific written approval of the Enterprise IT Security Department Manager must be obtained. Third Party Security Requirements - As a condition of gaining access to the BSU computer network, every third party must secure its own connected systems in a manner consistent with BSU requirements. Real-time connections between two or more in-house BSU computer systems				
must not be established unless Information Security has determined that such connections will not jeopardize the information security of sensitive data. Personally- owned systems must not be used to process any BSU information unless the systems have been approved for use by Information Security. The privileges permitted through this firewall or related access control system must be based on business				
needs and must be defined in an access control standard issued by the Enterprise IT Security Department (documentation available from the department). BSU must reserve the right to audit the security measures in effect on third party-connected systems without prior warning.				

Sentence	Status	Framework	Closest Control	Suggested Improvement
The establishment of electronic data interchange and other electronic business system arrangements is prohibited unless approved by both Enterprise IT Security Department and Information Systems Department.	Missing	PCI DSS	Until 31 March 2025, passwords must be a minimum length of seven characters in accordance	N/A
Information Security Reports - All users in receipt of information about system vulnerabilities must forward this information to the Enterprise IT Security Department, which will determine what action is appropriate. REPORTING PROBLEMS AND INCIDENTS What To Report - All employees must promptly report to the Enterprise IT Security Department any loss of, or severe damage to, their hardware or software.	Missing	CIS Controls v8	policies and guidance not to reuse passwords should be developed.	N/A
Employees must report these types of communications to their manager, the Human Resources and/or the Enterprise IT Security Department. All information security vulnerabilities known to exist must be reported. All instances of suspected disclosure of Sensitive or Confidential information also must be reported to the Enterprise IT Security Department for incident investigation. How To Report – A hotline has been				
established to handle information security problem reports.				

Sentence	Status	Framework	Closest Control	Suggested Improvement
Users must not redistribute system vulnerability information. Users must not possess software or other tools that are designed to compromise information security.	Missing	PCI DSS	default password is changed per Requirement	N/A
New Installations - Employees and vendors working for BSU must not make arrangements for, or actually complete, the installation of voice or data lines with any carrier unless they have obtained written approval from the Director of the Office of Telecommunications.	Missing	CIS Controls v8	passwords a user must manage. Users are recommended to use password manager	N/A
These third parties include information providers such as outsourcing organizations, business partners, contractors, and consultants working on special projects.	Missing	NIST CSF	Identify (ID)	N/A
Access Restrictions - Third-party information system vendors must be given only in-bound connection privileges when the DIT Systems Manager determines that they have a legitimate business need.	Missing	CIS Controls v8	policies and guidance not to reuse passwords should be developed.	N/A
These privileges must be enabled only for the time period required to accomplish previously defined and approved tasks.	Missing	SOC 2	prepared and communicated to authorized internal and external users of the system to permit	N/A
Third-party vendor access that will last longer than one day must be approved by the Enterprise IT Security Department.	Missing	CIS Controls v8	policies and guidance not to reuse passwords should be developed.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
ENCRYPTION Default Protection Not Provided - The Internet and other public networks are not protected from wiretapping by default. When To Use Encryption - Whenever confidential information is sent over a public computer network like the Internet, encryption methods authorized by the Enterprise IT Security Department must be used to protect it. If sensitive information is transmitted over public computer	Missing	PCI DSS	default password is changed per Requirement	N/A
networks such as the Internet, this transmission must take place with encryption facilities approved by Information Security.				
In all but a few rare instances, if information is to be protected, then the user must take specific action to enable encryption facilities. Whenever confidential information is stored in a computer, this storage must be with similar authorized encryption methods.	Missing	NIST CSF	management are established, communicated, understood, and enforced	N/A
Users who employ cellular or mobile phones must not store or discuss Sensitive (Confidential or Restricted) information unless they have taken steps to encrypt the information.	Weak	PCI DSS	do not store, process, or transmit any account data in electronic format on their systems or premises.	N/A
Video conferences must not involve discussion of sensitive information unless encryption facilities are known to be enabled.	Weak	CIS Controls v8	Applications and websites can also be used to harvest credentials, data, or attempt to	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
For more information about these circumstances, "Data Classification Quick Reference Table." Key Selection - Many encryption routines require that the user provide a seed or a key as input.	Missing	CIS Controls v8	applied to only allow those with a business need to access the data.	N/A
Users must protect these security parameters from unauthorized disclosure, just as they would protect passwords from unauthorized disclosure.	Missing	SOC 2	information is restricted to authorized internal	N/A
Rules for choosing strong seeds or keys must follow all rules for choosing strong passwords.	Missing	NIST CSF	are preserved	N/A
If a user goes on vacation or is otherwise unable to check their mail for extended periods, mail can be forwarded to another BSU employee.	Weak	PCI DSS	except those noted as Not in Place due to a legal restriction.	N/A
Out-of-office notices can be established that will automatically inform correspondents that the recipient will not be responding for a certain period of time.	Missing	NIST CSF	services, people) that enable the organization to achieve business purposes are identified	N/A
Never send an electronic mail message containing sensitive information outside the BSU network without end-to-end encryption.	Missing	NIST CSF	throughout the organization and with authorized third	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Contents Of Messages - Users must not use profanity, obscenities, or derogatory remarks in any electronic mail messages. Users must not respond directly to the originator of offensive electronic mail messages, telephone calls, or other communications. Harassing Or Offensive Messages - BSU information systems must not be used for the exercise of a user's right to free speech.	Weak	PCI DSS	administrators is authenticated via at least one of the	N/A
Such remarks may create legal problems such as trade libel and defamation of character.	Weak	ISO 27001	All employees of the organization and, where relevant, contrac-	N/A
Special caution is warranted because backup and archival copies of electronic mail made by both BSU and third parties may actually be more permanent and more readily accessible than traditional paper communications.	Missing	ISO 27001	Requirements for confidentiality or non-disclosure agreements	N/A
Sexual, ethnic, and racial harassment, including unwanted telephone calls, electronic mail, and internal mail, is strictly prohibited. Harassment of any type is strictly prohibited.	Missing	SOC 2	of confidential information is restricted to authorized parties to meet the entity's confidentiality	N/A
PRINTING, COPYING AND FAX TRANSMISSION Destruction Of Waste Copies - If a printer, copier, or fax machine jams or malfunctions when printing Sensitive or Confidential information, the involved users must not leave the machine until all copies of the sensitive information are removed or are no longer legible.	Missing	ISO 27001	Agreements with suppliers shall include requirements to address	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
All paper copies of sensitive information must be disposed of by shredding or other methods approved by the Enterprise IT Security Department. In departments that handle sensitive information copy machine hard drives must be purged of all data before the machine leaves the department. copy machines or printers with hard drives must agree to purge the storage device of all	Missing	CIS Controls v8	enterprise. Since email and web are the main means that users interact with external	N/A
university information before it is removed from the department.				
Faxing Precautions - Sensitive materials must not be faxed unless an authorized staff member is on-hand at the time of transmission to properly handle the materials at the receiving BSU site.	Missing	ISO 27001	of confidentiality, integrity and availability for information within the scope of the information	N/A
Sensitive information must not be faxed through untrusted intermediaries such as hotel staff or rented mailbox service staff. Confidential information may be faxed by Internet only if the connection is protected with encryption systems approved by the Enterprise IT Security Department.	Missing	PCI DSS	do not store, process, or transmit any account data in electronic format on their systems or premises.	N/A
All faxes must employ a standard cover page that includes language approved by the BSU General Counsel.	Missing	CIS Controls v8	An identity created for a person in a computer or computing system. For the purpose	N/A
Third-party signatures on contracts, purchase orders, and similar legal documents sent by fax must always be followed-up with an exchange of originals.	Missing	ISO 27001	Documented information required by the information security management system and by this	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Printer Precautions - When printing sensitive information, the user must be present at the printer at the time of printing to prevent the information from being revealed to unauthorized parties, or direct the output to a printer inside an area where only authorized employees are permitted.	Missing	CIS Controls v8	applications) on the network so that only authorized software is installed and can	N/A
Copy Machine Precautions - Unless permission from the copyright Owner is obtained, making multiple copies of material from magazines, journals, newsletters, and other publications is forbidden unless this is both reasonable and customary.	Missing	CIS Controls v8	Or worse, if directly connected, a ransomware attack could encrypt data on the	N/A
Many copy machines contain hard drives capable of storing information.	Missing	ISO 27001	COPYRIGHT PROTECTED DOCUMENT	N/A
Leasing and Repair Services - Only third-party vendors who have signed a BSU non-disclosure agreement can perform the repair of fax machines, printers, and copy machines.	Missing	CIS Controls v8	can include phone calls, emails, or letters. Keep in mind that certain mechanisms, such as emails, can be affected during a security	N/A
Third-party vendors of machines that contain storage devices e.g.	Missing	ISO 27001	Information transfer	N/A
MOBILE COMPUTING AND WORK AT HOME Approval For Remote Access - Remote access to BSU computers must be granted only to those users who have a demonstrable business need for such access. Permission to access BSU computers remotely is granted by and annually reviewed by a user's manager.	Weak	CIS Controls v8	dealing with user privacy. These may require compliance to regional or sector-specific	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
All remote users must attend a special class before remote access privileges are granted or annually renewed.	Missing	NIST CSF	cybersecurity capabilities and externally to oversee or communicate with third parties.	N/A
Location Independence - All security requirements apply at remote locations.	Missing	CIS Controls v8	applied to only allow those with a business need to access the data.	N/A
Sensitive information stored on computing devices or on paper must be kept in a secure manner.	Missing	ISO 27001	Information security incidents shall be responded to in accordance	N/A
The access control packages must prevent virus infections and other types of damage from malicious software.	Missing	CIS Controls v8	Also, the risk that an application vulnerability introduces might not be understood,	N/A
If it is necessary to remove computer-readable sensitive information from BSU offices, this information must be protected with encryption facilities provided by DIT and approved by Information Security. All portable and remote systems storing sensitive BSU information must also employ hard disk encryption systems. DIT must remove all software that is not authorized on systems that are used to process	Weak	SOC 2	of the system and have access to confidential information.	N/A
BSU information.				
Theft Of Equipment - If BSU information systems equipment is not stored in a locked area, users must employ anti-theft equipment such as locking cables to secure BSU equipment. If a secure area is not available, employ locking cables to secure BSU equipment.	Weak	PCI DSS	The intention of this requirement is not that an entity installs software in the systems or	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Users must not store passwords, user IDs, or any other access information in portable or remote systems. Both users and programmers must be careful never to embed user IDs, readable passwords, encryption keys, or other security parameters in any file.	Missing	ISO 27001	A.9.1 Business requirements of access control	N/A
Travel Considerations – Travelers are often the target of theft. When traveling Users must employ anti-theft techniques.	Missing	CIS Controls v8	third-party uses a fourth-party platform or product to support the main enterprise.	N/A
Store equipment in a secure area such as a locked room or auto trunk.	Missing	ISO 27001	Where required by the access control policy, access to systems and	N/A
Users must also be careful not to discuss sensitive information when in public places like hotel lobbies, restaurants, and elevators. Users must be careful not to provide sensitive information in voice mail messages or pager messages.	Missing	CIS Controls v8	privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.	N/A
Viewing sensitive information on a computer screen or hardcopy report is prohibited when a user is in a public place such as seated on an airplane.	Missing	CIS Controls v8	third-party vendor, designate at least one person internal to the enterprise to oversee any third-party work. Review	N/A
VIRUSES, MALICIOUS SOFTWARE, AND CHANGE CONTROL Virus Checking Required - Virus-checking systems provided by DIT and approved by the Enterprise IT Security Department must be in place on all personal computers with operating systems susceptible to viruses, on all firewalls with external network connections, and on all electronic mail servers.	Missing	CIS Controls v8	there is not a universal standard for assessing security; and, many service providers	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
All files coming from external sources must be checked before usage.	Missing	SOC 2	Confidential information is protected during	N/A
If encryption or data compression has been used, these processes must be reversed before the virus-checking process takes place.	Missing	SOC 2	Confidential information is protected during	N/A
Users must not turn off or disable virus-checking systems. Users must not remove viruses or malware on their own.	Missing	SOC 2	Confidential information is protected during	N/A
If A Virus/Malware Infection Is Detected - If users obtain infection alerts, they must immediately disconnect from all networks and cease further use of the affected computer, and call the Help Desk for technical assistance.	Weak	ISO 27001	Requirements for confidentiality or non-disclosure agreements	N/A
If users believe they may have been the victims of other malicious software, they must immediately call the Help Desk to minimize the damage.	Missing	CIS Controls v8	Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure	N/A
User possession or development of viruses or other malicious software is prohibited.	Weak	CIS Controls v8	"Confidential," and "Public," and classify their data according to those labels. Review and update the classification scheme annually, or	N/A
Change Control - Users must not install new or upgrade operating systems or application software on BSU business computing devices.	Missing	ISO 27001	The allocation of secret authentication information shall be con-	N/A
These computing devices have been specifically recognized as systems used for regular university business activities.	Weak	CIS Controls v8	password-policy-guide/	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
This approach permits DIT to perform automatic software distribution, automatic software license management, automated remote backup and related functions on a centralized and coordinated basis.	Weak	CIS Controls v8	Business Email Compromise	N/A
While change control will be maintained through the above-mentioned access control packages, users can, however, change the personal preferences of software packages e.g.	Weak	ISO 27001	The organization shall supervise and monitor the activity of out-	N/A
change fonts for a word processing package, organize email messages folders, etc.	Missing	CIS Controls v8	traversing the network, once they are inside.	N/A
Academic Research - Research that involves development of viruses or other malicious software must not be conducted on computing machines that are connected to the BSU business network. Research that requires the modification of the operating system or application software must not be conducted on computing machines that are connected to the BSU business network.	Missing	PCI DSS	do not store, process, or transmit any account data in electronic format on their systems or premises.	N/A
These types of research are both legitimate and important scholarly work that like all research must be conducted in a controlled environment. It is important that this type of research be: 1.	Weak	ISO 27001	Information involved in electronic messaging shall be appropri-	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Registered and approved in writing by the BSU Provost, and 2. that the IT Enterprise Security Department is informed in writing, and 3. that the research is conducted in an environment that is separated from the BSU business network.	Weak	SOC 2	and confidentiality failures, incidents, concerns, and other complaints to appropriate parties.	N/A
PERSONAL USE OF INFORMATION SYSTEMS Personal Use - All user activity is subject to logging and subsequent analysis.	Weak	CIS Controls v8	recovery prioritization, and the security of backup data. Review and update documentation annually, or when	N/A
Users must not perform any activity on BSU information systems that could damage the reputation of BSU.	Weak	ISO 27001	Objective: To ensure that information and information processing facilities are protected against	N/A
Such conduct could lead to disciplinary action up to revocation of network access privileges and termination of employment.	Weak	CIS Controls v8	can include phone calls, emails, or letters. Keep in mind that certain mechanisms, such as emails, can be affected during a security	N/A
Testing Prohibition - Users must not test or attempt to compromise any information security mechanism unless specifically authorized to do so by the Enterprise IT Security Department.	Missing	CIS Controls v8	personnel to report to, mechanism for reporting, and the minimum information to be reported. Ensure the process is publicly available to	N/A
(See registered Academic Research exception above.)	Weak	ISO 27001	Records shall be protected from loss, destruction, falsification,	N/A
Making Copies Of Software - Users must not make copies of or use software unless they know that the copies are in keeping with the vendor's license to BSU.	Missing	CIS Controls v8	Securely dispose of data as outlined in the enterprise's data management process. Ensure the disposal process and method are	N/A
Questions about licensing must be directed to DIT, which maintains documentation reflecting software licenses throughout BSU.	Weak	ISO 27001	Technical compliance	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
Making regular backups of software for contingency planning purposes is permissible.	Missing	PCI DSS	do not store, process, or transmit any account data in electronic format on their systems or premises.	N/A
These labels will be important for management decision-making purposes, and will demonstrate that BSU observed appropriate copyright and other intellectual property laws.	Missing	SOC 2	Confidential information is protected during	N/A
SYSTEMS DEVELOPMENT Production System Definition - Information systems that have been designated production systems have special security requirements. Special Production System Requirements - All software developed in-house that runs on production systems must be developed according to a recognized development methodology (SDM).	Weak	ISO 27001	Fax + 41 22 749 09 47	N/A
A production system is a system that is regularly used to process information critical to BSU business.	Weak	PCI DSS	Signature of Merchant Executive Officer ■	N/A
Although a production system may be physically situated anywhere, the production system designation is assigned by the Enterprise Systems Manager.	Weak	ISO 27001	Objective: To ensure that information and information processing facilities are protected against	N/A
The SDM also must ensure that production systems include adequate control measures.	Missing	ISO 27001	COPYRIGHT PROTECTED DOCUMENT	N/A
IT Enterprise Security must perform periodic risk assessment of production systems to determine whether the controls employed are adequate.	Missing	ISO 27001	Backup copies of information, software and system images shall be	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
All production systems must have an access control system to restrict who can access the system and restrict the privileges available to these users. A designated systems administrator who is not a regular user on the system must be assigned to control access for all production systems.	Missing	CIS Controls v8	Train workforce members on how to identify and properly store, transfer, archive, and destroy sensitive data. This	N/A
Separation between Production, Development, and Test Systems - Where resources permit, there must be a separation between the production, development, and test environments.	Weak	CIS Controls v8	or a patch has been issued. These can support internal or industry compliance	N/A
All security fixes provided by software vendors must go through the systems development methodology testing process, and must be promptly installed.	Missing	CIS Controls v8	Any type of storage device that can be removed from a computer while the system	N/A
DIT Enterprise Systems, Enterprise Application and Functional Support Departments must follow formal and documented change control processes to restrict and approve changes to production systems.	Weak	CIS Controls v8	remote access.	N/A
All application program-based access paths other than the approved user access paths must be deleted or disabled before software is moved into production.	Missing	CIS Controls v8	privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.	N/A
This documentation must be preserved for audit inspection.	Missing	CIS Controls v8	security requirements.	N/A
User Programming - Users must not write production computer programs unless specifically authorized by the Chief Information Officer.	Missing	SOC 2	Confidential information is protected during	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
The construction of spreadsheet formulas, automatic execution scripts that are run when a system is booted, or databases is not considered programming for purposes of this document.	Missing	ISO 27001	Access control	N/A
Employees must report all suspected compromises to BSU information and systems.	Missing	CIS Controls v8	that provide adequate security. Acquire these components from trusted sources or evaluate the software for vulnerabilities before use.	N/A
Reports must not be sent by electronic mail, unless encrypted.	Missing	SOC 2	Confidential information is protected during	N/A
EXCEPTIONS Risk Acceptance - In some rare cases, the business case for non-compliance can be established. In all such cases, the non-compliance situation must be approved in advance through a risk acceptance process.	Missing	CIS Controls v8	standardized, currently accepted, and extensively reviewed encryption algorithms. Operating systems also provide	N/A
This process requires a risk acceptance memo signed by a Department Manager, reviewed IT Enterprise Security, IT Information Systems and approved by the area Vice President and the DIT VP/CIO. Further details on the risk acceptance process can be obtained through Enterprise IT Security Department.	Missing	ISO 27001	Security of equipment	N/A
BSU is obligated to notify the appropriate law enforcement authorities of any unlawful activity and to cooperate in any investigation of such activity.	Missing	PCI DSS	do not store, process, or transmit any account data in electronic format on their systems or premises.	N/A

Sentence	Status	Framework	Closest Control	Suggested Improvement
BSU does not consider conduct in violation of an information security rule to be within an employee's or partner's course and scope of employment, or the direct consequence of the discharge of the employee's or business partner's duties. Accordingly, to the extent permitted by law, BSU reserves the right not to defend or pay any damages awarded against employees or	Missing	CIS Controls v8	While many attacks occur on the network, others involve physical theft of portable	N/A
business partners that result from violation of this rule or any BSU Policy it enables.				
Any employee or business partner who is requested to undertake an activity which he or she believes is in violation of this rule, must provide a written or verbal complaint to his or her manager, any other manager, the Human Resources Department, or the Enterprise IT Security Department as soon as possible.	Missing	ISO 27001	Security of equipment	N/A